

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA5112

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

Total Marks: 50

Annexure A

Code of Conduct:

I Bhavya PS(192524017) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.



Signature of the student:

Annexure A

1. Secure Password Storage in Web Applications

A web application stores user passwords and needs to protect them against database breaches.

- A. Explain why storing plaintext passwords is insecure.
 - B. Suggest a secure method for storing passwords and justify your choice.
-

2. Digital Signature for Document Authentication

A company wants to ensure that official documents sent electronically are authentic and unaltered.

- A. Explain how digital signatures can be used in this scenario.
 - B. Justify how this method ensures both integrity and non-repudiation.
-

3. Preventing Replay Attacks in Online Transactions

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

- A. Explain how replay attacks occur.
 - B. Suggest a cryptographic technique to prevent such attacks and justify your answer.
-

4. Secure Communication over Public Wi-Fi

A user accesses sensitive information using a public Wi-Fi network without encryption.

- A. Identify the risks involved in this scenario.
 - B. Recommend a secure communication method and justify how it protects user data.
-

5. Data Integrity in Cloud Storage

An organization stores critical data in a cloud server and wants to ensure that the data is not altered.

- A. Explain how hashing can be used to verify data integrity.
 B. Suggest an additional mechanism to enhance trust and justify your answer.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

1. Secure Password Storage in Web Applications

A. Explain why storing plaintext passwords is insecure.

Storing passwords in plaintext means the passwords are saved exactly as users type them, without any protection or encryption. This is one of the most dangerous security practices because anyone who gains access to the database can immediately read every user's password.

Why plaintext passwords are insecure:

- **Easy target during database breaches:** If hackers steal the database, they instantly obtain every password.
- **Password reuse risk:** Many users use the same password across multiple websites. Attackers can use stolen passwords to access email, banking, or social media accounts.
- **Insider threats:** Database administrators or employees with database access can view users' passwords.
- **No confidentiality:** Passwords remain visible in human-readable form.
- **Violation of security standards:** Modern cybersecurity standards strongly prohibit storing passwords in plaintext.

Example

Instead of storing:

Username: Alice

Password: Welcome123

The attacker immediately knows the password.

If the database is leaked, every account becomes compromised.

Conclusion

Therefore, storing plaintext passwords exposes users to identity theft, financial loss, unauthorized access, and privacy violations.

B. Suggest a secure method for storing passwords and justify your choice.

The safest method is to store passwords using a **strong password hashing algorithm** with a unique **salt** for every password.

Examples include:

- bcrypt
- Argon2 (recommended)
- scrypt

Working Process

1. User creates a password.
2. The system generates a random salt.

3. The password and salt are combined.
4. A hashing algorithm produces a fixed-length hash.
5. Only the hash and salt are stored.

Example:

Password:

Welcome123

Stored value:

Salt: A92XK8

Hash: 6fd3a9b71c4d...

The original password is never stored.

Why this method is secure

- Hashing is **one-way**, so the original password cannot be recovered.
- A unique salt prevents identical passwords from producing identical hashes.
- It protects against rainbow table attacks.
- Modern algorithms such as bcrypt and Argon2 intentionally require more computation, making brute-force attacks extremely difficult.

Conclusion

Password hashing with salt provides strong confidentiality and remains the industry standard for secure password storage.

2. Digital Signature for Document Authentication

A. Explain how digital signatures can be used in this scenario.

A digital signature is a cryptographic technique that proves both the authenticity and integrity of an electronic document.

Steps involved

1. The sender prepares the document.
2. A hash of the document is generated.
3. The sender encrypts the hash using their private key.
4. The encrypted hash becomes the digital signature.
5. The document and signature are sent together.
6. The receiver computes the document hash.
7. The receiver decrypts the signature using the sender's public key.
8. If both hashes match, the document is authentic.

Example

Company Director sends an employment offer letter.

- Document Hash → Generated
- Hash encrypted using Director's private key
- Signature attached
- Employee verifies using Director's public key

If any part of the document changes, verification immediately fails.

B. Justify how this method ensures both integrity and non-repudiation.

Integrity

- Even a one-character modification changes the hash completely.
- During verification, mismatched hashes indicate document tampering.

Example:

Original:

Salary = ₹50,000

Modified:

Salary = ₹90,000

The hash changes completely, so verification fails.

Non-Repudiation

Only the sender owns the private key.

Therefore:

- Nobody else can generate the same signature.
- The sender cannot later deny signing the document.

This provides legal proof of document ownership.

Conclusion

Digital signatures guarantee:

- Authentication
- Integrity
- Non-repudiation

making them ideal for secure electronic documents.

3. Preventing Replay Attacks in Online Transactions

A. Explain how replay attacks occur.

A replay attack occurs when an attacker captures a valid communication and retransmits it later to trick the system into accepting it again.

Example

Customer sends:

Transfer ₹10,000

An attacker intercepts this request.

Later, the attacker resends the exact same transaction.

If the server accepts it again, another ₹10,000 is transferred.

Why replay attacks succeed

- No timestamp validation
- No unique transaction identifier
- No session freshness checking
- Messages remain valid indefinitely

Consequences

- Duplicate payments
- Unauthorized transactions
- Financial fraud
- Loss of trust

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

The best solution is to use **nonces (numbers used once)** along with timestamps and message authentication.

Working

Each transaction contains:

Transaction Amount

Timestamp

Nonce

Digital Signature or MAC

The server stores previously used nonces.

If the same nonce appears again, the transaction is rejected.

Example

First transaction

Nonce = 84512

Accepted.

Attacker replays the message.

Server detects:

Nonce already used

Transaction rejected.

Why this works

- Every request is unique.
- Old requests cannot be reused.
- Timestamps reject delayed messages.
- Digital signatures prevent message modification.

Conclusion

Using nonces, timestamps, and authenticated messages effectively prevents replay attacks.

4. Secure Communication over Public Wi-Fi

A. Identify the risks involved in this scenario.

Public Wi-Fi networks are often unsecured, allowing attackers to intercept communications.

Risks

- Password theft
- Credit card theft
- Identity theft
- Session hijacking
- Man-in-the-middle attacks
- Eavesdropping
- Data modification
- Malware injection

Example

A user logs into internet banking over open Wi-Fi.

Without encryption, attackers can capture:

- Username

- Password
- Banking session

This may lead to unauthorized account access.

B. Recommend a secure communication method and justify how it protects user data.

The recommended method is HTTPS (TLS/SSL encryption). For additional protection on public Wi-Fi, using a VPN (Virtual Private Network) is also highly recommended.

HTTPS

HTTPS encrypts all communication between the browser and the web server.

VPN

A VPN creates an encrypted tunnel between the user's device and the VPN server.

Protection provided

- Encrypts transmitted data
- Prevents eavesdropping
- Prevents packet modification
- Verifies server identity through certificates
- Protects login credentials
- Reduces the risk of man-in-the-middle attacks

Example

Without HTTPS:

Username = Alice

Password = 12345

can be intercepted.

With HTTPS/VPN:

Encrypted Data

Attackers cannot read the transmitted information.

Conclusion

HTTPS combined with a VPN provides confidentiality, authentication, and secure communication over public Wi-Fi.

5. Data Integrity in Cloud Storage

A. Explain how hashing can be used to verify data integrity.

Hashing generates a fixed-length value (hash) from a file.

Working

1. Original file uploaded.
2. SHA-256 hash generated.
3. Hash stored securely.
4. Later, the file is downloaded.
5. A new hash is generated.
6. Both hashes are compared.

If they match:

Data is unchanged.

If they differ:

Data has been modified or corrupted.

Example

Original file:

Report.pdf

SHA-256 Hash:

A1B7D9E34F...

After downloading:

A1B7D9E34F...

Hashes match → File integrity verified.

If even one bit changes, the new hash becomes completely different.

Benefits

- Fast verification
- Detects accidental corruption
- Detects malicious modification
- Efficient for large files

B. Suggest an additional mechanism to enhance trust and justify your answer.

An effective additional mechanism is a Digital Signature.

Working

1. Generate the file hash.
2. Encrypt the hash with the owner's private key.
3. Store or send the signature with the file.
4. Users verify it using the public key.

Why this enhances trust

- Confirms the file originated from the legitimate owner.
- Detects any modification.
- Prevents forgery.
- Provides authentication, integrity, and non-repudiation.

Other complementary mechanisms include:

- Message Authentication Codes (MACs) for shared-secret verification.
- Blockchain-based audit logs for tamper-evident records.
- Regular integrity audits and secure backups.

Conclusion

Hashing verifies whether data has changed, while digital signatures prove both the integrity of the data and the identity of its sender. Together, they provide a strong and trustworthy solution for securing cloud-stored data.